

Дизайн: iOS-приложение для VPN-сервиса с продажей через Telegram

Дата: 2026-09-30 (ред. 2026-10-02) Статус: на ревью Масштаб: ~1000 пользователей Макет: [docs/design/mockup.html](#) — 21 состояние, актуален на 2026-10-02

1. Задача

Дать клиентам существующего Telegram-бота бесшовный iOS-клиент: человек покупает подписку в **Telegram**, а приложение само получает конфиг с нашего сервера и подключается по OpenVPN. Пользователь не скачивает файлы и не задумывается о настройке.

2. Зафиксированные решения

Вопрос	Решение
Протокол	OpenVPN (инфраструктура проверена, клиенты подключаются через OpenVPN Connect)
Продажа	Только Telegram. Вне области этого документа
Канал доставки	TestFlight, публичная ссылка
Аккаунт разработчика	Зарубежный Apple ID, физлицо, \$99/год
Авторизация	Вход через бота (deep link + polling)
Приложение	Своё, брендированное
Исходный код	Открытый (публичный репозиторий)
Отзыв доступа	Через существующую БД: дроп записи конфигурации
Бюджет на лицензии	Нулевой
Единица доступа	Подключение (конфиг) , не страна. На одну страну может быть несколько конфигов

Приложение **не является** VPN-сервисом по духу Guideline 5.4: оно не продаёт и не предоставляет VPN-услугу, а выступает клиентом для уже оплаченного стороннего доступа. Это позиция, снижающая риск 5.4, но не устраняющая его (см. §7).

3. VPN-движок и лицензия

Выбор: TunnelKit на зафиксированном коммите.

Почему именно он, а не Partout:

- **Partout требует платную лицензию.** Автор прямо пишет: распространение через App Store не укладывается в GPLv3, поэтому нужна коммерческая лицензия. Тарифы привязаны к MAU, стартовый до 10 000. Открытие исходников это не снимает — блокер не в закрытости кода, а в несовместимости GPLv3 с распространением через Apple (требование §6 об Installation Information).
- **TunnelKit имеет то, чего нет у Partout:** дополнительное разрешение по GPLv3 §7 специально на поставку через App Store. В сочетании с открытыми исходниками (закрывающими саму GPL-обязанность) это даёт полностью легальную и бесплатную конфигурацию.

Издержка: **TunnelKit архивирован 15 апреля 2025** и не развивается. Ответственность за совместимость с нашими профилями лежит на нас.

Что сделать до первой строки кода:

1. Зафиксировать конкретный commit, зависимости и дословный текст дополнительного разрешения.
2. Проверить его на **реальных .ovpn** из продакшена — что все используемые директивы обрабатываются.
3. Осознанно принять: исправлений от автора не будет.

Важно: «конфиг работает в OpenVPN Connect» **не означает**, что он заработает в TunnelKit. TunnelKit описывает свою реализацию как упрощённую. Это отдельная проверка, а не предположение.

4. Что показало исследование

Ограничения, которые нельзя обойти технически:

1. **TestFlight-сборки перестают запускаться через 90 дней.** Безусловно, без продления.
2. **Apple Developer Program License Agreement запрещает** брать плату с Beta Testers и использовать TestFlight для «continuous distribution... in an attempt to circumvent App Store».
3. **Guideline 5.4** требует, чтобы VPN-приложения публиковались организацией.

Что работает в нашу пользу:

- TestFlight доступен в РФ-STORE, смена региона и Apple ID не нужны.
- Действующие РФ-провайдеры (NvoVPN, MosVPN, WAY VPN, «Дядя Ваня РФ») раздаются через TestFlight.
- Продажа вне приложения не требует IAP: в приложении нет ни покупок, ни призывов к покупке.

Технический флаг (не блокер): с декабря 2025 ТСПУ блокирует OpenVPN, L2TP и WireGuard. Конфиги пользователя при этом коннектятся. Значит, блокировка либо не повсеместна, либо на серверах есть обфускация. Риск отложен, но отслеживается.

5. Энтайтлменты

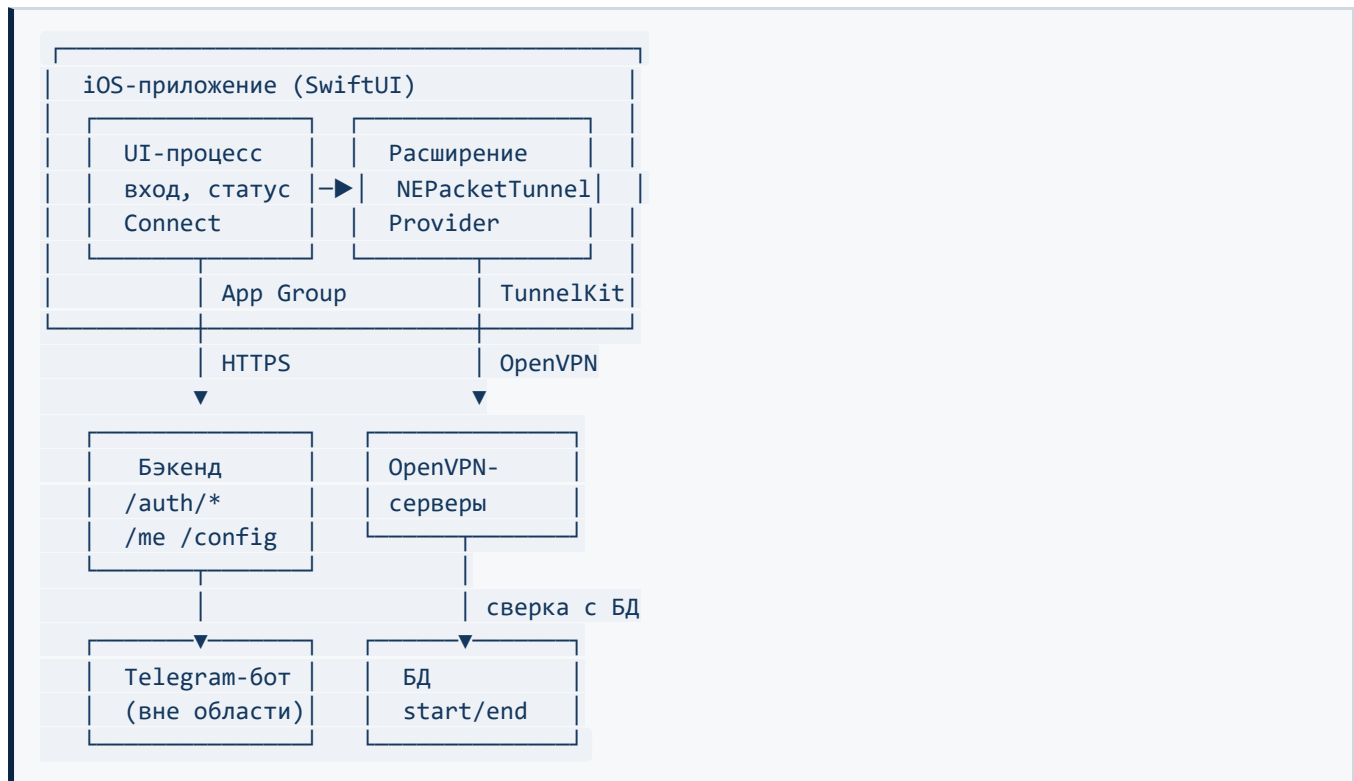
`com.apple.developer.networking.networkextension` со значением `packet-tunnel-provider` — **self-serve с 2016 года**. Запрос к Apple не нужен, одобрение не требуется: capability включается в Xcode и в App ID на портале. Форма нужна только для managed-типов (Hotspot Helper, NE app push), к нам не относится.

Тип аккаунта (физлицо или организация) на этом слое не влияет.

Понадобится App Group для передачи конфига между приложением и расширением.

Personal VPN (`com.apple.developer.networking.vpn.api`) решается при реализации. Он нужен для `NEVPNManager` , но для `NEPacketTunnelProvider` обычно достаточно `packet-tunnel-provider` . Если всплывёт `saveToPreferences → Code 5 "permission denied"` , значит нужен и он.

6. Архитектура



Разделение ответственности:

- **UI-процесс** — состояние и инициация подключения. Логики туннеля нет.
- **Расширение (NEPacketTunnelProvider)** — единственное место, где живёт VPN. Отдельный системный процесс.
- **App Group** — канал передачи конфига. Требует дисциплины записи (см. §8.2).
- **Бэкенд** — выдаёт профиль активным подписчикам.
- **БД** — источник истины по срокам. См. §7 об отзыве.

7. Отзыв доступа

Отзыв реализуется через существующую БД: записи даты начала и конца конфигурации, дроп записи прекращает доступ.

Условие, при котором это работает: OpenVPN-сервер должен **сам** сверяться с БД при подключении — через `client-config-dir` , `auth-user-pass-verify` или management-интерфейс.

Если конфиг самодостаточный (сертификат и ключ вшиты внутрь файла), удаление строки в БД уже выданный конфиг не остановит: он продолжит работать, пока сертификат не отозван на сервере.

Это единственное, что нужно проверить, чтобы вопрос был закрыт. Дальнейшей проработки не требует.

8. Потоки

8.1 Вход по deep link

```
Юзер в приложении → «Войти через Telegram»  
→ приложение открывает t.me/<bot>?start=login_<публичный код>  
→ пользователь жмёт inline-кнопку «Подтвердить вход» в боте  
  (не /start: у платящего клиента Start заменён полем ввода)  
→ бот кладёт: публичный код → chat_id  
→ приложение опрашивает /auth/poll, предъявляя СЕКРЕТ  
→ получает сессионный токен → Keychain
```

Разделение кода и секрета обязательно. Публичный код виден в ссылке и в чате; секрет получения сессии генерируется приложением и через Telegram не проходит. Иначе знание ссылки позволяет постороннему обменять её на сессию первым.

Дополнительно: явное подтверждение в боте с показом кода, ограничение попыток, атомарная смена состояния операции.

8.2 «Обновить профиль» и запись конфига

```
Кнопка → GET /config → бэкенд проверяет подписку  
→ .ovpn со свежими серверами  
→ ЗАПИСЬ: во временный файл → валидация → атомарная замена  
→ последняя рабочая версия сохраняется для отката
```

Атомарность обязательна. Один битый `.ovpn`, записанный в общий контейнер, ломает подключение у всех до ручного вмешательства. Схема: temp + rename, валидация до применения, хранение предыдущей версии, откат при ошибке.

При выходе из аккаунта конфиг очищается — иначе следующая сессия подхватит профиль предыдущего пользователя.

8.3 Подключение

Кнопка Connect → `NETunnelProviderManager` (система один раз спрашивает разрешение) → расширение читает конфиг из App Group → туннель через TunnelKit.

Конфигурация туннеля — часть продукта, а не деталь:

- DNS — какие серверы, что при их недоступности.
- Маршрутизация IPv4 и IPv6 — **IPv6 обязан быть закрыт**. Утечка IPv6 в обход туннеля деанонимизирует клиента.

- **Kill switch** — поведение при обрыве. `.ovpn` этого не покрывает: решается на стороне приложения через `includeAllNetworks`.
- Критерий успеха — **реальный трафик через туннель**, а не системный статус «подключено».

8.4 Возврат из фона

Опрос `/auth/poll` **не может** идти непрерывно: iOS приостанавливает приложение через несколько секунд после ухода в фон. Пока пользователь в Telegram, приложение будет остановлено.

Решение: сохранять незавершённую операцию входа и возобновлять проверку при возврате в foreground (наблюдение `scenePhase`). Сценарии для проверки: длительное нахождение в Telegram, перезапуск приложения, отсутствие Telegram на устройстве.

8.5 Экраны и навигация

Полный макет со всеми состояниями: [docs/design/mockup.html](https://docs.google.com/design/mockup/html) (21 экран, актуален на 2026-10-02).
Ниже — только правила и контракты, без дублирования вёрстки.

Единица списка — подключение, а не страна. На одну страну может быть несколько конфигов («Нидерланды · Амстердам» и «Нидерланды · Роттердам»). Это влияет и на заголовок секции («Подключения»), и на формулировки («Выбрать другое», а не «другую страну»).

Состав состояний:

- Вход: ожидание подтверждения, проверка входа, нет Telegram
- Главный: не подключено, подключение, проверка защиты, **проверка не пройдена**, подключено и защищено, смена подключения, ошибка, эскалация ожидания (10/20/30 сек)
- Список: нет подписок, один истёк, все истекли, доступ отозван
- Разрешение: прайминг системного диалога, отказ в разрешении, инструкция «Как включить VPN»
- Аккаунт, подтверждение смены подключения, предупреждение о сборке, демо-режим

Правила:

- **Статус у каждого подключения свой.** Один конфиг истёк — остальные работают. Экран не блокируется целиком.
- **Смена подключения = переподключение** с подтверждением. Пока туннель опущен, показывается окно без защиты.
- **Выбранное подключение сохраняется** между запусками.
- **Зелёное — только после проверки.** См. §8.3.

Главная кнопка — одна, в фиксированном нижнем баре, меняет текст и заливку по состоянию:

Состояние	Кнопка
Не подключено	белая «Подключить»
Подключение	ghost «Отменить»
Проверка защиты	ghost «Отключить»
Проверка не пройдена	ghost «Отключить»
Подключено	ghost «Отключить»
Ошибка / эскалация	белая «Повторить»
Нет разрешения VPN	белая «Открыть Настройки»
Всё истекло	белая «Обновить доступ»
Подписок нет	белая «Обновить»
Доступ отозван	белая «Обновить доступ»

Форма ответа бэкенда. `/me` отдаёт массив подключений:

```
GET /me → { chat_id, configs: [{ id, name, location, start_date, end_date, status }] }
GET /config/{id} → .ovpn для конкретного подключения
```

Наружу ведут только сервисные действия: поддержка, «Войти другим Telegram», обновление приложения по ссылке из бота. **Призывов к покупке в интерфейсе нет** — кнопка «Продлить в Telegram» убрана как нарушение анти-стиринга 3.1.1. Об истечении сообщает нейтральный текст, а главная кнопка обновляет данные, а не продаёт.

9. Дизайн

Полный макет: `docs/design/mockup.html1` . Стиль — тёмная приборная панель, сдвинутая в синеву.

Токены:

Роль	Значение
Фон	<code>#0a0c10</code> → <code>#12151b</code> → <code>#1a1e26</code>
Границы	<code>#262b34</code> карточки, <code>#5a6472</code> интерактив
Текст	<code>#e8ecf2</code> основной, <code>#aab4c2</code> вторичный, <code>#8b95a3</code> приглушённый
Акцент	<code>#6fb3ff</code> — только выделение и фокус
Состояния	<code>#3ddc97</code> зелёный, <code>#ffb454</code> янтарный, <code>#ff5f6d</code> красный

Правила семантики цвета — нарушение считается дефектом:

1. **Ложная уверенность в защите хуже отсутствия защиты.** Зелёное «подключено» нельзя выводить из системного статуса — только после подтверждения, что трафик реально идёт через туннель. До замера пишется «не проверено».
2. **Красный — только реальная опасность** (окно без защиты при смене подключения, обрыв). Не для «выключено».
3. **Янтарный — только процесс подключения.** Не для сроков подписки.
4. **У бренда нет своего цвета.** Главная кнопка белая; цветовая хроматика отдана состоянию.
5. **Технические значения** (даты, адреса, id) — моноширинным.
6. **Никаких обещаний защиты без замера** — «утечек нет», «IPv6 закрыт» до проверки не показывать.

9.1 Проработка интерфейса

Проведено три раунда мультиагентной проработки: 36 агентов, ~5 млн токенов. Раунды шли от сценариев прохода к тестированию по признанным методикам.

Раунд 1 — сценарии пользователей. Пять линз (новичок, опытный, отказы, злоупотребление, доступность), 50 кейсов. Найдено 22 класса проблем. Главные: зелёный статус врал; состояния «не подключено» не существовало вообще (после обрыва пользователь застревал с кнопкой «Отключить» на то, что не подключено); отказ в разрешении VPN был тупиком, потому что системный диалог показывается один раз; список обрезался при четырёх странах.

Раунд 2 — новые линзы по исправленному макету. Шесть перспектив (холодный старт, реализуемость одним разработчиком, полгода эксплуатации, движение и микровзаимодействия, живые конкуренты, взгляд ревьюера Apple), 60 кейсов. Найдено два blockers, угрожающих каналу раздачи: **ревьюер Apple не может пройти дальше первого экрана** (у него нет подписки — состояния 2–11 недостижимы, он ревьюит пустое приложение вслепую), и **онбординг учил оплате**, а «Продлить в Telegram» стояла главной кнопкой — это анти-стиринг 3.1.1. Введён демо-режим и убраны призывы к покупке.

Раунд 3 — тестирование по методикам. Пять признанных методов вместо выдуманных линз: эвристики Нильсена, когнитивный обход, WCAG 2.2 AA с точными токенами, симуляция лабораторного теста, тестирование отказоустойчивости. 80 находок, 41 к починке, свёрнутые в 18 уникальных дефектов. Затем спор защитника и обвинителя и голосование четырёх независимых судей.

Измеримые правки по WCAG (пересчитаны вручную, подтверждены):

Было	Число	Стало
Приглушённый текст на карточках	4.39:1 — ниже AA	токен осветлён → 5.22:1
Приглушённый текст на плотном фоне	4.01:1 — ниже AA	тот же токен лечит оба фона
Границы ghost-кнопок	1.59:1 — ниже 3:1	новый токен <code>#5a6472</code> → 3.05:1
Включённый тумблер	2.99:1, только цветом	сплошная заливка + рамка
«Отменить» в окне без защиты	4.00:1 от приглушения	прозрачность убрана
Системная зона внизу	не учтена	<code>env(safe-area-inset-bottom)</code>
Зоны касания тумблера и чекбокса	29pt и 23pt	обёрнуты в $\geq 44pt$

Смысловые правки: устранён ложный зелёный на экране проверки (четыре методики сошлись на одном дефекте); добавлен третий исход гейта — «Трафик не идёт через туннель» (без него остаются только вечное «проверяем» или ложный зелёный); матрица кнопки приведена в соответствие с экранами; исправлена невыполнимая инструкция «отправьте `/start`» (у платящего Start заменён полем ввода, а аудитория — именно платящие); убрано обещание автообновления, которого не будет; удаление аккаунта получило деструктивный стиль и подтверждение; добавлен выход «Войти другим Telegram» для смены аккаунта.

Какой метод что даёт — вывод на будущее:

- **Нильсен и когнитивный обход** — всё про деньги, доступ и безопасность. Лучшее соотношение цены и пользы.
- **WCAG и HIG** — лучшая измеримость, но и шум: требования к семантике и фокусу статичный макет выполнить не может по определению. Доступность проверять на живом устройстве с VoiceOver, а не по картинке.
- **Отказоустойчивость** — больше всего шума: синтетические инъекции (длинный IPv6, замеры обрезки в фиксированном кадре) почти все отклонены как артефакты. Эдж-кейсы вынести в интеграционные тесты.

Спор агентов окупился. Обвинитель пересчитал числа за тестировщиками и нашёл у них четыре ошибки: неверный охват дефекта, ошибку в легенде цветов, недооценку включённого тумблера и пропущенное обещание «увеличить контраст» без реализации. Без стадии спора три неверные находки уехали бы в правки.

10. Биллинг — вне области

Продажа и оплата в Telegram вне этого документа. Бот не трогаем.

Отдельно, к вашему сведению (не входит в работы): правила Telegram требуют Telegram Stars для цифровых товаров и услуг, продаваемых внутри ботов, независимо от наличия внешнего сайта. Текущая схема — внешний шлюз YooKassa. Считается ли конкретно VPN-подписка «цифровым товаром» в терминах правил — вопрос трактовки, но за неподчинение Telegram скрывает бота. Это проверяется независимо от мобильного приложения. Упомянется один раз, решения не требует.

11. Риски

Риск	Оценка	Митигация
Допустимость TestFlight не подтверждена	критическая	5.4 требует организацию; APGLA прямо запрещает бессрочную раздачу и плату с бета-тестеров. Держать план на случай отказа Beta App Review
Сборка перестаёт работать через 90 дней	гарантированно	Авто-релиз каждые ~60 дней через CI (fastlane + GitHub Actions). Вручную не выживет
TunnelKit не поддерживается	высокая	Pin коммита, вендоринг, проверка на реальных профилях, готовность к форку
Бан аккаунта разработчика	средняя	Зарубежный Apple ID, не связанный с РФ
Удаление по требованию РКН	средняя	Apple удалила 1000+ VPN-приложений точно. TestFlight задевает меньше, гарантий нет
Утечка IPv6/DNS при обрыве	средняя	Kill switch и закрытие IPv6 — обязательные требования (\$8.3)
ТСПУ начнёт валить OpenVPN	средняя	Наблюдать. Миграция на VLESS/Reality — отдельная техническая работа (\$11)

Чего в таблице намеренно нет: ёмкость инфраструктуры, эксплуатационный контур с RPO/RTO, метрические панели, PKI-контур. Для 1000 пользователей и одного разработчика это переразмер. Обязательный минимум отсюда — бэкапы подписок и запрет логирования приватных ключей и токенов.

12. Смена протокола — если понадобится

Утверждение «переход на VLESS/Reality не затрагивает архитектуру» **неверно**. Изменится движок, формат конфигурации, интеграция расширения, серверная часть, тестовая матрица.

Точная формулировка: **смена протокола не требует переписывать весь продукт, но является отдельной технической миграцией с выпуском новой версии клиента.**

Переиспользуются: интерфейс, авторизация, каркас расширения, схема доставки конфига.

Стратегия «ждать массовых жалоб» заменяется на измерение: успешность подключения по целевым сетям и операторам, а не доступность серверов из дата-центра.

13. Что сознательно не делаем

- **Не продаём из приложения.** Покупок и призывов к покупке в приложении нет вообще — оплата, продление и оформление остаются в боте.
- **Не пишем свой OpenVPN-движок.**
- **Не поддерживаем iOS ниже 15.**

- **Не мигрируем на VLESS сейчас.**
- **Не строим эксплуатационный контур** (мониторинг, RPO/RTO, реагирование) — отложено.
- **Не вводим микросервисы.**
- **Не выносим абстракцию «профиль подключения» из `.ovpn`** — преждевременно.

14. Порядок работ

Последовательность изменена против первой редакции: сначала снимаем неопределённости, которые могут обесценить разработку, затем отказные сценарии, потом пилот.

Этап 0 — до вложений:

1. Зафиксировать commit TunnelKit, зависимости, дословный текст разрешения.
2. Проверить TunnelKit на **реальных `.ovpn`** из продакшена.
3. Определить способ отзыва на стороне сервера (§7) и подтвердить, что дроп записи действительно прекращает доступ.
4. Собрать пробную сборку и получить одобрение Beta App Review.

Этап 1 — каркас:

5. Зарубежный Apple ID + Developer Program, App ID с энтайтлментами.
6. Приложение + расширение, туннель на статичном конфиге.
7. Конфигурация туннеля: DNS, IPv6, kill switch, критерий успеха.

Этап 2 — потоки:

8. Бэкенд: `/auth/link`, `/auth/poll`, `/me`, `/config`.
9. Вход через бота с разделением кода и секрета, возобновление при возврате из фона.
10. «Обновить профиль» с атомарной записью и откатом.

Этап 3 — до платящих:

11. Испытания на реальных устройствах: смена Wi-Fi и мобильной сети, сон, блокировка экрана, перезагрузка, отсутствие интернета, длительное подключение.
12. CI для авто-релиза каждые 60 дней.
13. Закрытое тестирование, затем публичная ссылка.

Этапы 1 и 2 частично параллельны.

15. Открытые вопросы

1. **Конфигурация OpenVPN-серверов** — есть ли серверная сверка с БД (§7). Единственное, что осталось проверить по отзыву.
2. **Лимит устройств** — не определён. Влияет на схему выдачи: один профиль на пользователя или на устройство.
3. **Поведение при истечении подписки** — что видит пользователь, когда профиль перестает обновляться.

16. Уточнения против первой редакции

Исправлено по итогам разбора:

- ~~«Тестер теряет приложение вместе с логином и локальными данными»~~ → Apple документирует только недоступность сборки; судьба локальных данных не определена. Формулировка нейтральная.
- ~~«TunnelKit / Partout, GPLv3 с разрешением под MPL 2.0»~~ → смешение двух разных лицензионных моделей. Выбран TunnelKit; про MPL убрано.
- ~~`срок = now + N`~~ → `max(текущая_дата_окончания, now) + оплаченный_период`. Иначе досрочное продление сжигает остаток.
- ~~«Смена протокола не затрагивает архитектуру»~~ → отдельная миграция с новой версией клиента.
- ~~«Бесшовная ротация, не требует действий»~~ → обновление по кнопке, с атомарной записью и откатом.
- ~~«Риск 5.4 низкий, но не нулевой»~~ → «допустимость модели не подтверждена», критическая значимость для канала.
- ~~«App Group — достаточно»~~ → требуется протокол согласованной записи.
- ~~«Бэкапный аккаунт как механизм восстановления»~~ → перенос требует версии в App Store; для TestFlight-модели это только ре-аплоад. Одна строка, работ не порождает.